SANS



AI Security Maturity Model™

A Practical Framework for Building a Mature AI Security Program

Author: **Chris Cochran**

Field CISO and VP of AI Security, SANS Institute

TABLE OF CONTENTS

Introduction 3

How to Use This Model 4

The Three Pillars of AI Security 5

The Five Stages of AI Security Maturity 6

- Unaware / Ad Hoc 8
- Reactive / Policy-Emerging 10
- Defined / Risk-Informed 12
- Managed / Integrated 14
- Optimizing / Adaptive 16

Determining Your Target Maturity 18

Assessment and Scoring 19

SANS AI Security Maturity Model Self-Assessment 20

Calculating Your AI Security Maturity Score 22

Quick Reference: AI Security Maturity Model™ Cheat Sheet 24

Mature Your Program with SANS 25

Attribution and Sources 26

About the Author 27

INTRODUCTION

The SANS AI Security Maturity Model™ is the operational companion to the **SANS Secure AI Blueprint**. That Blueprint defines three specific priorities with respect to AI adoption: Protect AI, Utilize AI, and Govern AI. This book provides guidance on when and how to act.

It provides a structured path from little or no AI governance to industry leadership, with specific controls, metrics, and actions at each stage. The result is a practical guide for practitioners and executives moving from strategy to execution.

The 'right' level of maturity is not universal, it is determined by your organization's specific AI adoption pattern, industry, regulations, and risk tolerance. A company running basic SaaS AI features has different priorities than a defense contractor building agentic systems. The AI Security Maturity Model™ is designed for organizations at any starting point to assess the maturity of planning, executing, or existing AI activity.

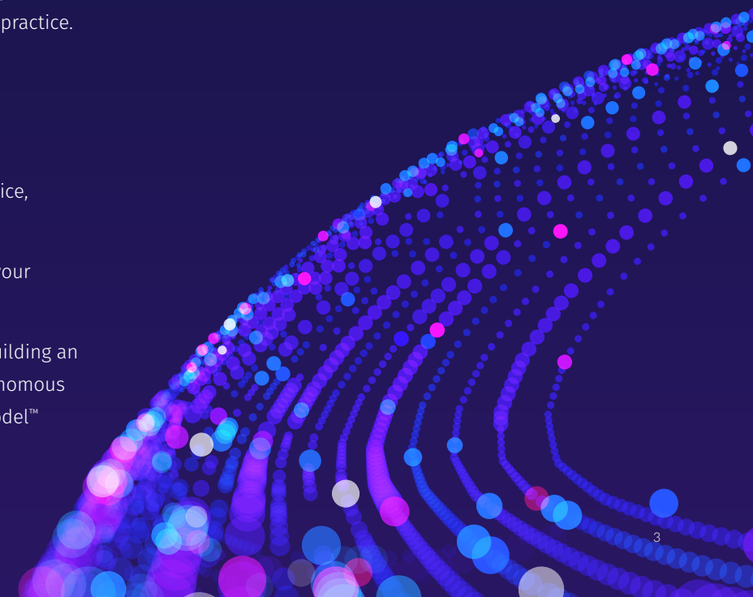
This framework was developed in alignment with the OWASP AI Exchange and the OWASP Agentic Top 10, incorporating SANS's formal partnership with OWASP on AI security standards, and maps to NIST AI RMF, the EU AI Act, ISO 42001, and CSA AICM. It is the connective tissue between what the broader security community has agreed upon and what your team actually implements in day-to-day practice.

In this document, you will learn how to:

- Use the model to assess your current AI security maturity,
- Understand what each stage looks like in practice,
- Identify the steps needed to advance, and
- Align your progress with the global standards your regulators and customers expect.

Whether you are establishing your first AI policy, building an AI-powered red teaming program, or securing autonomous AI agents in production, the AI Security Maturity Model™ provides a proven structure for getting there.

"The 'right' level of maturity is not universal, it is determined by your organization's specific AI adoption pattern, industry, regulations, and risk tolerance."



HOW TO USE THIS MODEL

The AI Security Maturity Model™ operates on a simple cycle: assess your current position honestly, set a defensible target, close the gap, and reassess.

1. Start by reading the Program Indicators at each stage and identifying which description matches your current reality, not your roadmap, but your evidence.
2. Walk each pillar independently using the self-assessment (**p.20**); most organizations are not at the same stage across Protect, Utilize, and Govern, and that asymmetry is exactly what the model is designed to surface.
3. Calculate your weighted score (**p. 22**), then use the Determining Your Target Maturity table to set your goal. Follow the Steps to the Next Level in sequence. They are ordered intentionally, and skipping ahead builds controls around an incomplete picture.

Note: Not all steps apply to every organization, and Stage 5 maturity may not be necessary.

For enterprise organizations:
Embed AI Security Maturity Model™ scoring into your existing risk management cadence, apply your industry weighting profile, and use the pillar scores as executive-ready reporting language. Map this to existing and emerging regulatory, ISMS, cloud, and AI frameworks.

For smaller organizations:
Scale the structures to your organization without abandoning the logic. Your "AI Governance Council" may be one named person with a clear mandate and 90 minutes a week. Your "AI asset inventory" may be a shared spreadsheet with four columns: Tool Name, Data Access, Owner, Approved.

A 30-person company at a genuine, evidence-based Stage 2 is in a stronger security posture than an enterprise claiming Stage 3 without documentation to prove it. Name an owner, inventory your AI tools, write a one-page policy, brief your team, and reassess in 90 days. That sequence moves most small organizations from Stage 1 to Stage 2 within a single quarter.

> "A 30-person company at a genuine, evidence-based *Stage 2* is in a stronger security posture than an enterprise claiming *Stage 3* without documentation to prove it."

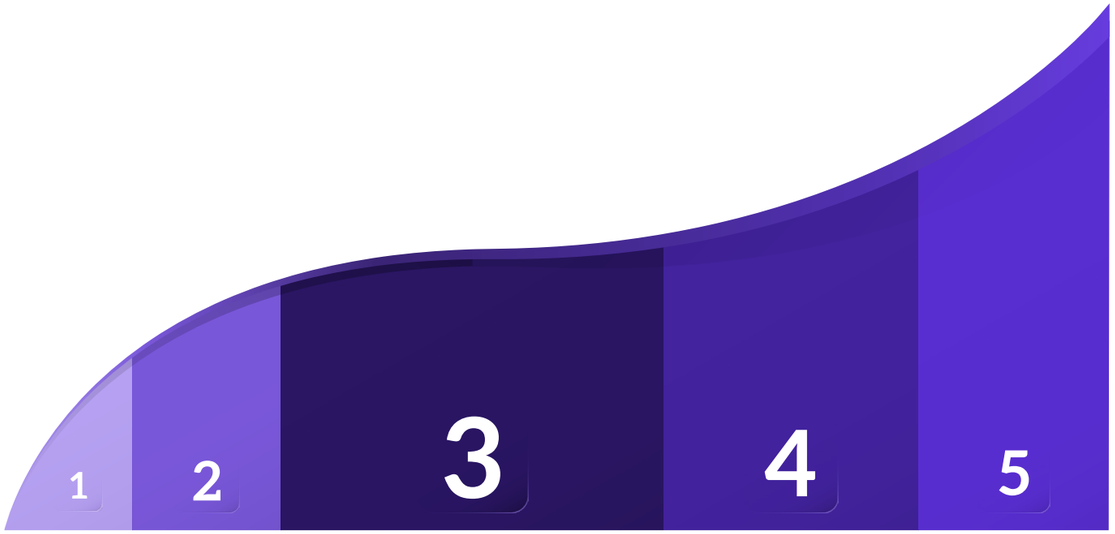
THE THREE PILLARS OF AI SECURITY

The model is built on three critical dimensions that must be balanced for a secure AI program. These pillars align directly with the **SANS Secure AI Blueprint** tracks.



THE FIVE STAGES OF AI SECURITY MATURITY

The model outlines a progression from ad hoc usage to adaptive, AI-native operations. Not every organization needs to reach Stage 5. The right maturity level depends on your AI adoption rate, industry, regulatory environment, risk tolerance, and business objectives.



Timeline estimates are based on practitioner experience across SANS engagements and should be treated as directional rather than prescriptive benchmarks. Actual timelines vary significantly based on organization size, existing program maturity, and available resources.

CRITICAL STRATEGIC DRIVERS

AGENTIC AI AND IDENTITY

Organizations should first apply the Principle of Least Agency, confirming that agentic autonomy is genuinely required and cannot be accomplished through a simpler, less autonomous architecture, before scoping agent permissions and identity. (The Principle of Least Agency is the agentic analogue to the well-established Principle of Least Privilege.) Once agentic operation is justified, the model explicitly addresses the shift toward action-taking AI by mandating NHI management and documented human owners for AI agents beginning at Stage 3.

DATA MATURITY

A critical prerequisite for advancing to Stage 2 is having data classification in place. You cannot write an effective AI policy without knowing where sensitive data lives.

INCIDENT OWNERSHIP

The framework distinguishes between two incident categories: Security incidents (prompt injection, data exfiltration, and model theft, owned by the Security team) and Safety/Reliability incidents (harmful bias, hallucination, and legal liability, owned by Legal/Risk) and where they overlap or are shared.

TERMINOLOGY

AGENT IDENTITY / NHI

The specific service account, credential, or token assigned to an AI agent to authenticate, authorize, and track its actions independently from human users.

AI AGENT

An AI system equipped with tools, API access, and a degree of autonomy to plan and execute actions, as opposed to purely conversational AI.

AI-WASHING

The vendor practice of marketing simple analytics or rules-based systems as "AI" without genuine machine learning capabilities.

AGENTIC AI

A system of AI agents that solve complex, multi-step goals with minimal supervision.

BRING YOUR OWN AI (BYOAI)

A policy-neutral term for employees using personal or unapproved AI tools for work purposes. Analogous to Bring Your Own Device (BYOD).

SHADOW AI

BYOAI that violates an existing organizational policy or occurs without organizational awareness, the negative behavioral state. Shadow AI only applies where policy exists (Stage 2 and above).

STAGE 1

UNAWARE / AD HOC

DESCRIPTION

Stage 1 represents an organization with no formal AI security approach. Employees use public AI tools, ChatGPT, Copilot, Gemini, and others, without oversight or awareness of risks. Developers may download models from repositories, such as Hugging Face without verification, or consume AI capabilities through managed cloud platforms such as AWS Bedrock or Google Vertex AI without organizational awareness or controls.

There is no AI governance, no consideration of AI in security operations, and no protection of any internal AI implementations. Leadership may be unaware of the extent of AI usage across the organization.

Because no AI policy exists at this stage, employee use of personal or unapproved AI tools is classified as BYOAI, not yet Shadow AI, which requires an existing policy to violate.

VALUE

Organizations at Stage 1 face significant unmanaged risk. Sensitive data may be leaked to public AI models, unmanaged AI usage creates compliance exposure, and opportunities to leverage AI for security improvement are missed. Without formal AI governance, organizations are exposed to data exfiltration risk from AI-augmented threats that legacy security controls are not designed to detect or stop. Recognizing this starting point creates urgency to establish foundational controls.

PROGRAM INDICATORS

PROTECT

- No inventory of AI tools in use
- No understanding of AI-specific threats
- Any internal AI/ML models are unprotected
- No visibility into the AI supply chain
- Developers may be pulling models from Hugging Face or similar repositories without verification
- No visibility into third-party AI agents or plugins granted access to corporate environments

GOVERN

- No AI usage policy exists
- BYOAI proliferates unchecked
- No visibility into what AI tools employees are using
- No AI risk assessment has been conducted
- Leadership unaware of AI exposure
- No distinction is made between conversational AI and action-taking AI

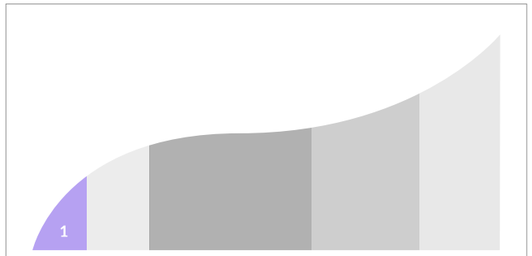
UTILIZE

- No AI/ML used in security tools or operations
- The security team is unaware of available AI capabilities
- Manual processes dominate detection and response

PEOPLE INDICATORS

- Employees freely use public AI tools with sensitive data
- No training exists on AI risks or acceptable use
- IT and Security are unaware of AI tools present in the environment
- No individual or team is accountable for AI governance

"Without governance, *Utilize* becomes uncontrolled experimentation and *Protect* lacks policy authority."



STEPS TO THE NEXT LEVEL

To advance beyond Stage 1, establish foundational visibility and accountability:

1. Conduct a BYOAI discovery survey
2. Assign an AI governance owner and define the RACI
3. Draft an initial AI acceptable use policy
4. Communicate the policy and expectations to the workforce
5. Inventory existing AI/ML capabilities in security tools
6. Implement basic access controls (blocklist or allowlist)
7. Conduct an initial AI risk assessment
8. Provide basic AI awareness training tailored to organizational risks
9. Establish basic AI supply chain visibility

PREREQUISITES FOR STAGE 2

Before advancing, ensure basic data classification is in place. An effective AI policy cannot be written without knowing where sensitive data lives. If data classification is absent, address it first, as AI maturity depends on data maturity.

STAGE 2

REACTIVE / POLICY-EMERGING

DESCRIPTION

Stage 2 represents an organization that has recognized AI as a risk area and established basic controls. An AI acceptable use policy exists, though it may be simple, is often "don't use AI" or "use with caution." Public AI tools are either blocked entirely or allowed without oversight or logging. Security tools may include AI features, but they are used at default settings without intentional configuration. Leadership is aware of AI at a high level but has not prioritized strategic investment.

A block-based AI policy may feel like risk management, but practitioner experience shows it typically drives AI usage underground rather than preventing it. This is the pattern SANS has documented as the "Framework of No," and it is why the Stage 2 to Stage 3 transition is so critical. The goal is not to eliminate AI use; it is to bring it into visibility where it can be governed.

VALUE

A Stage 2 program establishes baseline controls and a policy foundation. It reduces the most obvious risks, blatant data leakage to public models, and creates a starting point for more sophisticated governance. The organization can demonstrate basic due diligence on AI risk.

PROGRAM INDICATORS

PROTECT

- Inventory of sanctioned AI tools exists but may be incomplete
- Basic understanding of AI risks at the leadership level
- No AI-specific security testing
- Basic visibility into where models originate
- Awareness that pickled model files (a common serialization format that can harbor malicious code) and unverified sources pose risk
- Basic awareness of the risks of granting AI tools API access or system integrations

UTILIZE

- Security tools with AI-based features used but not intentionally configured
- No customization or tuning of AI security features
- Basic spam/malware detection using vendor AI
- No AI strategy for security operations
- Security team lacks AI/ML skills
- No validation of vendor AI claims

GOVERN

- AI acceptable use policy published; may be binary rather than nuanced.
- Data classification for AI usage is absent or incomplete
- Basic awareness training mentions AI risks
- No AI risk register
- No cross-functional AI governance body
- Policy begins to differentiate between conversational AI and AI granted permission to take actions

PEOPLE INDICATORS

- Employees are aware a policy exists but unclear on details
- Some compliance with policy, but workarounds are common
- Security team is beginning to learn about AI threats
- No dedicated AI security expertise

POTENTIAL METRICS

PROTECT

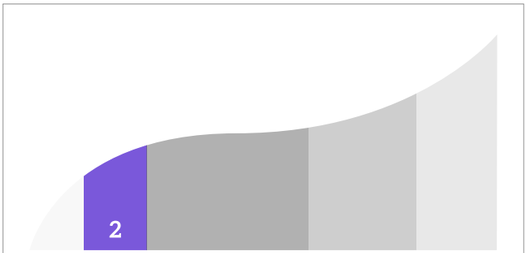
- Number of known AI tools in use
- Number of sanctioned AI tools with documented data access and ownership
- Number of third-party AI integrations identified but not yet assessed

UTILIZE

- No metrics at this stage

GOVERN

- Percentage of employees acknowledging the AI acceptable use policy
- AI policy violations detected
- Completion rate of AI awareness training
- Number of Shadow AI incidents detected (dependent on monitoring capability)
- Number of AI tools added to the enterprise risk register
- Number of BYOAI discovery findings resolved or remediated



STEPS TO THE NEXT LEVEL

1. Establish a cross-functional AI governance body or council
2. Conduct technical BYOAI discovery
3. Develop a comprehensive AI policy framework
4. Create AI-specific data classification processes
5. Implement AI-aware DLP controls
6. Deploy sanctioned AI tools and evaluate enterprise AI gateway solutions
7. Add AI risks to the enterprise risk register
8. Develop AI security training for technical staff
9. Evaluate AI capabilities for security operations
10. Create AI vendor assessment criteria
11. Implement AI usage monitoring and logging at the application level
12. Document at least a partial AI asset inventory

PREREQUISITES FOR STAGE 3

Before advancing, the following must be in place: a governance body formed with cross-functional representation, the security team has completed baseline AI training, and at least a partial AI asset inventory is documented.

STAGE 3

DEFINED / RISK-INFORMED

DESCRIPTION

Stage 3 marks the transition to intentional, risk-informed AI security. The organization has formal AI governance with cross-functional oversight. AI usage is controlled through enterprise tools rather than outright bans. Security teams actively leverage AI capabilities and are building AI-specific skills. AI systems are included in security assessments, and AI risks are tracked formally.

VALUE

A Stage 3 program enables controlled AI adoption that balances innovation with security. The organization can demonstrate mature AI governance to regulators, customers, and partners. Security operations benefit from AI capabilities, and AI systems are protected against known threats.

For organizations with limited AI deployment and a non-critical AI attack surface, Stage 3 is a strong and defensible operating position. Organizations processing regulated data, running customer-facing AI, or operating in sectors actively targeted by nation-state actors should treat Stage 3 as a milestone, not a destination.

PROGRAM INDICATORS

PROTECT

- Complete inventory of AI systems and models; AI included in asset classification
- Data flows to and from AI systems are documented and maintained with data lineage visibility
- Internal AI agents assigned distinct NHIs with strict access control
- AI tool and API access strictly scoped
- Prompt injection and instruction manipulation defenses implemented
- Input validation and output filtering deployed
- AI systems included in penetration testing scope; basic adversarial emulation and testing conducted
- Model provenance verification in place
- Controls mapped to MITRE ATLAS™ techniques
- Runtime validation of dynamically loaded agent tools and plugins
- Secure agent-to-agent communication and mutual authentication

UTILIZE

- AI-powered threat detection tuned to the environment
- AI-assisted alert triage and prioritization in place
- Behavioral analytics (User and Entity Behavior Analytics (UEBA)) deployed and customized for anomaly detection
- AI-assisted automated playbooks deployed for common scenarios
- AI-powered threat intelligence enrichment
- Security team trained on AI/ML fundamentals
- Assess genuine AI/ML capabilities and environment compatibility
- Model cards and adversarial testing results are requested from vendors as part of procurement

GOVERN

- AI Governance Council established with cross-functional membership, defined charter, decision authority, and regular review cadence
- Comprehensive AI policy addressing use cases and data classification
- AI ethics guidelines established
- Third-party AI assessment requirements defined
- AI risks included in the enterprise risk register with a defined assessment methodology
- AI-specific incident response procedures in place
- Human-in-the-loop thresholds and automated policy enforcement (policy decision points, intent gates, and consequence-based checks) defined for high-risk agent workflows
- Every deployed AI agent has a documented human owner
- Structured logging with trace IDs across agent steps and tool calls

PEOPLE INDICATORS

- Employees assessed on AI policy nuances and select AI tools based on data sensitivity
- Security team is competent with AI security tools
- AI Security Specialist and AI Governance Lead roles are being defined or filled
- Cross-functional collaboration on AI decisions is established
- AI risks are discussed during project planning

POTENTIAL METRICS

PROTECT

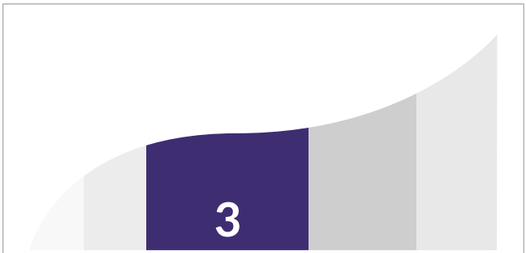
- AI systems with completed security assessments
- AI vulnerabilities remediated within organization-defined service level agreements (SLAs)
- AI-specific incidents detected
- Percentage of AI agents mapped to a dedicated NHI

UTILIZE

- AI-detected threats vs. manually detected threats
- Alert volume reduction attributable to AI triage
- Mean Time to Detect (MTTD) (AI-assisted vs. baseline)
- Efficiency gains per security FTE

GOVERN

- Approved AI tools vs. Shadow AI instances detected
- Policy compliance rate
- AI risk assessment completion rate
- Training completion rate for AI-specific roles



STEPS TO THE NEXT LEVEL

1. Implement an AI risk analysis
2. Deploy an AI red teaming program
3. Develop an AI security metrics dashboard
4. Implement continuous AI monitoring
5. Integrate AI security into Continuous Integration and Continuous Delivery (CI/CD) pipelines
6. Build an advanced AI threat hunting capability
7. Develop AI-specific Security Orchestration, Automation, and Response (SOAR) playbooks
8. Implement model security operations (MLSecOps)
9. Establish AI security architecture standards
10. Develop predictive AI risk analytics

PREREQUISITES FOR STAGE 4

Formal risk quantification methodology adopted, AI red team capability initiated, MLSecOps pipeline started, and board-level AI risk reporting established.

STAGE 4

MANAGED / INTEGRATED

DESCRIPTION

Stage 4 represents mature, quantitatively managed AI security. AI is deeply integrated into security operations with measurable outcomes. AI systems are secured by design with comprehensive testing and monitoring. AI governance is embedded in enterprise processes with quantified risk management. Decisions are data-driven, and AI security performance is predictable.

This level is typically required for organizations with significant AI deployment, those in regulated industries, or those facing advanced threats. Organizations facing AI-augmented adversaries, which increasingly means most organizations, need the machine-speed defense capabilities that Stage 4 builds. Stage 3 detection speeds, tuned for human-pace adversaries, are increasingly insufficient against threats that operate at dramatically faster operational tempos.

VALUE

A Stage 4 program demonstrates ROI on AI security investments, enables confident AI adoption at scale, and provides assurance to stakeholders. The organization can handle sophisticated AI-specific threats and leverage advanced AI capabilities for security.

PROGRAM INDICATORS

PROTECT

- Security integrated into the AI/ML development lifecycle
- Threat modeling required for all AI systems
- Confused Deputy defenses deployed to isolate untrusted inputs from agent execution tools
- Execution guardrails with real-time monitoring for AI agent API calls
- Comprehensive AI model and agentic red teaming program (Note: AI red teaming is distinct from traditional penetration testing, focusing on adversarial inputs, prompt injection, model extraction, and behavior manipulation)
- Controls for cascading failures in multi-agent systems. When one agent fails or gets compromised, the failure can propagate through shared memory, delegated tasks, or trusted communication channels
- Automated adversarial testing integrated into CI/CD pipelines
- MITRE ATLAS™ alignment covering the full kill chain, including exfiltration and impact tactics
- Automated model scanning and provenance verification
- Real-time prompt injection detection
- MLSecOps implemented: secure model training pipelines, model versioning and provenance, and training data validation

Just as detection and response capabilities must operate at machine speed to counter AI-augmented adversaries (see Stage 4 Utilize), authorization decisions for agent actions face the same tempo pressure. Organizations at Stage 3 and 4 should implement automated policy enforcement and Just-in-Time (JIT) access controls (intent validation, consequence-based authorization gates, and real-time scope evaluation) for routine agent actions, reserving manual human-in-the-loop review for high-impact, irreversible operations where the latency cost is justified by the risk.

UTILIZE

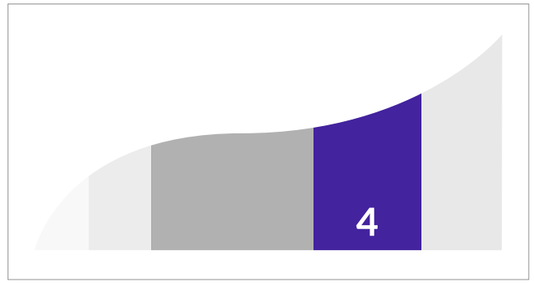
- Custom ML models developed for organization-specific threat detection
- AI-powered deception technologies and honeypots deployed
- Autonomous response enabled for defined, validated scenarios
- Security Orchestration, Automation, and Response (SOAR) platform enhanced with AI-driven decision support
- AI-powered threat hunting operational
- Predictive threat analytics in use
- Continuous model tuning with A/B testing and automated retraining

GOVERN

- AI governance integrated with enterprise risk management
- Board-level AI risk reporting established
- Quantitative AI risk methodology adopted (e.g., Factor Analysis of Information Risk (FAIR) extended to address AI-specific risk scenarios)
- AI risk appetite and tolerance formally defined
- Proactive monitoring of AI regulations and standards
- AI ethics board or review process in place
- Bias and fairness monitoring operational
- Reasoning traceability and decision audit artifacts
- Formal NHI lifecycle management with automated credential rotation and decommissioning

PEOPLE INDICATORS

- AI security training and development across the security team
- Organizations at this stage typically employ specialist roles; AI/ML Security Engineers, AI Incident Response Orchestrators, and AI SOC Engineers, where demand is accelerating rapidly
- Product managers and IT collaborate with security before AI development begins
- Business units are required to consult security on AI projects
- The general workforce can identify common AI failure modes and is trained to escalate AI anomalies



POTENTIAL METRICS

PROTECT

- AI red team findings severity trend
- Adversarial test pass/ fail rate
- AI incident MTTD and Mean Time to Repair (MTTR)

UTILIZE

- Custom model detection accuracy
- Autonomous response success rate
- AI-enabled MTTR improvement

GOVERN

- Quantified AI risk exposure, (Annualized Loss Expectancy (ALE))
- AI risk treatment ROI
- Regulatory compliance readiness score
- AI ethics review completion rate

STEPS TO THE NEXT LEVEL

1. Develop autonomous AI security capabilities
2. Implement AI-powered chaos engineering
3. Build predictive AI governance
4. Establish an AI security research program
5. Develop industry AI security contributions
6. Implement adaptive AI architecture
7. Build an AI security innovation lab
8. Develop AI threat simulation capability
9. Achieve AI security certifications and mature controls validation
10. Mentor other organizations on AI security

Prerequisites for These Steps:

- Measurable effectiveness of AI security controls
- Continuous monitoring and validated response capability
- Executive sponsorship and sustained funding
- Active AI security research and external engagement

PREREQUISITES FOR STAGE 5

Active AI security research program established, autonomous response capabilities validated in production, published contributions to AI security standards or community, and Zero Trust architecture fully extended to autonomous AI agents.

STAGE 5

OPTIMIZING / ADAPTIVE

DESCRIPTION

Stage 5 represents the frontier of AI security maturity. The organization operates with AI-native security, where AI is fundamental to security operations rather than an enhancement. AI systems are protected by adaptive, self-improving defenses. AI governance anticipates future requirements and drives competitive advantage. The organization contributes to the broader AI security community and shapes industry standards.

Elements of this stage exist primarily in large technology companies, defense contractors, and AI-native firms at the leading edge of AI security. For most organizations, Stage 5 is a multi-year trajectory, not a near-term target

VALUE

A Stage 5 program positions AI security as a business differentiator. The organization can pursue the most sensitive AI use cases, respond to novel AI threats with agility, and maintain resilience as AI technology evolves rapidly.

PROGRAM INDICATORS

PROTECT

- Self-improving AI defenses
- Autonomous adversarial detection operational
- AI system chaos engineering conducted continuously
- Zero Trust architecture fully extended to autonomous AI agents with context-aware, JIT permissions
- AI systems demonstrate antifragile properties
- Continuous AI security validation

UTILIZE

- AI agents authorized for Level 1 remediation
- Self-healing security infrastructure operational
- Predictive defense deployment
- Generative AI used for threat simulation
- AI-powered attack prediction operational
- Cross-organization AI threat correlation in place
- AI security research and development program

GOVERN

- AI governance enables a competitive advantage
- Predictive regulatory compliance capabilities established
- Board-level possesses AI expertise
- AI governance frameworks developed and published
- Regulatory body engagement
- Governance processes anticipate AI evolution
- Proactive policy adaptation

PEOPLE INDICATORS

- AI security expertise is an organizational differentiator
- The security team includes AI researchers
- AI governance recognized externally
- Talent attracted by AI security leadership
- The organization mentors others on AI security

POTENTIAL METRICS

PROTECT

- Frequency and effectiveness of self-improving defense adaptations
- Chaos engineering exercise outcomes and resilience scores
- Time to autonomous detection of novel adversarial techniques

UTILIZE

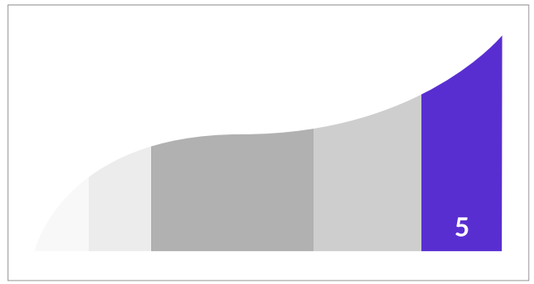
- Autonomous remediation success rate and scope coverage
- Predictive defense accuracy (threats anticipated vs. threats observed)
- Research output contributing to new detection capabilities

GOVERN

- Number of regulatory or standards body engagements
- External recognition of governance program (publications, citations, peer recognition)
- Lead time on regulatory preparedness (days ahead of effective date)

MAINTAINING STAGE 5

Stage 5 requires continuous evolution: anticipating AI technology changes, maintaining adaptive capacity, contributing to the broader AI security community, continuously challenging practices, and developing the next generation of AI security leaders.



"An untrained workforce using powerful AI tools is a governance emergency."

DETERMINING YOUR TARGET MATURITY

The appropriate maturity stage depends on your organization's profile. Use this reference to set a defensible target.

Organization Profile	Target Stage	Risk If Below Target
Minimal AI usage, basic SaaS features	Stage 2	Unmanaged data leakage to public AI models; compliance exposure
Moderate AI adoption, some internal projects	Stage 3	No formal governance over a growing AI footprint; incident response gaps
Significant AI investment, AI in business processes	Stages 3–4	AI systems deployed without security-by-design; quantified risk absent
AI-native company, AI products/services	Stage 4	Vulnerable to model theft, prompt injection, and supply chain attacks that have become commodity threats
AI in critical/regulated systems	Stages 4–5	Regulatory non-compliance; stakeholder trust erosion
AI industry leader, competitive differentiator	Stage 5	Loss of competitive position; inability to respond to novel threats at machine speed

CRITICAL NOTE ON WORKFORCE AI LITERACY

Organizations with high AI adoption but low workforce AI literacy face amplified human error risk. These organizations must prioritize AI Governance maturity to Stage 3 immediately, regardless of their technical threat landscape. An untrained workforce using powerful AI tools is a governance emergency.

ASSESSMENT AND SCORING

The AI Security Maturity Model™ uses an evidence-based scoring methodology designed for repeatability across assessors, industries, and organizational contexts.

THE MATURITY EVIDENCE SCALE

Every assessment question is scored on a 0–5 scale. This measures not just whether a capability exists, but how mature its implementation is.

Score	Level	Evidence Standard
0	Not Present	No evidence this capability exists
1	Ad Hoc	Anecdotal evidence only; no documentation; depends on individual effort
2	Developing	Written plan or draft policy exists; partial implementation
3	Established	Approved policy/procedure; consistent execution; stakeholder awareness confirmed
4	Measured	Documented metrics; dashboards or reports; evidence of data-driven decisions
5	Optimizing	Evidence of iterative refinement; trend analysis; proactive adaptation

Self-reported capabilities without documentary evidence cap at a score of 2. Examples include approved policies, configuration screenshots, test results, audit logs, and dashboard exports.

SAMPLE ASSESSMENT TOPICS

To illustrate how the assessment evaluates maturity, the following are representative topic areas from each pillar. The full assessment includes detailed scoring criteria and evidence requirements for each question.

PROTECT

Can you enumerate every AI system, agent, and model in your environment, including employee-adopted tools and demonstrate that each has documented ownership, data classification, and scoped access controls?

Key assessment criteria

- AI asset inventory completeness and classification coverage
- Authorization controls specific to AI agent tool access

UTILIZE

If an adversary injected a malicious instruction into a document your AI agent processed right now, how long before your team would know, and could you reconstruct exactly what the agent did after ingesting it?

Key assessment criteria

- Detection capability for prompt injection and model manipulation attempts
- Incident response procedures specific to AI system compromise

GOVERN

When your AI agent takes an action that causes harm, e.g., a regulatory violation, data exposure, a wrong decision at scale, who is accountable, and can you produce an audit trail that proves the chain of authority from human authorization to agent action?

Key assessment criteria

- Organizational ownership and accountability assignments for AI security
- Policy coverage for employee use of unsanctioned AI tools (BYOAI)

SANS AI SECURITY MATURITY MODEL™ SELF-ASSESSMENT

Rate each question on a score from 0-5. Self-reported capabilities without documented evidence cap at level 2.

PROTECT | SECURING AI IMPLEMENTATIONS

1	**AI Asset Inventory & Ownership** Can you produce a current inventory of every AI system, model, and agent used in your environment, with documented owner, data classification, and approved use case?	0-1	No inventory; AI usage discovered incidentally.
		2	Inventory exists for sanctioned tools only; known gaps.
		3	Comprehensive; classifications, owners, and approved use cases documented.
		4	Inventory coverage and drift tracked as metrics; reviewed on cadence.
		5	Continuous automated discovery and reconciliation.
2	**AI Supply Chain & Model Provenance** For every model, plugin, third-party agent, and AI service you consume, can you verify origin, integrity, and risk before deployment?	0-1	No verification; models pulled freely from public sources.
		2	Awareness of risks; ad hoc manual checks.
		3	Verification process in place; vendor assessments documented.
		4	Automated model scanning integrated into procurement and deployment pipelines.
		5	Continuous supply chain validation with real-time integrity attestation.
3	**AI Agent Identity & Authorization** Are AI agents granted distinct, scoped credentials (Non-Human Identities) with documented human owners and least-privilege access to tools, data, and APIs?	0-1	Agents share/reuse human or service credentials; no scoping.
		2	Some agents have distinct credentials; access not consistently scoped.
		3	Every agent has a distinct identity, scoped access, and a documented human owner.
		4	Formal NHI lifecycle with automated credential rotation and decommissioning.
		5	Zero Trust extended to agents with context-aware, just-in-time permissions.
4	**Adversarial Testing & AI Red Teaming** How rigorously do you test AI systems against prompt injection, model extraction, instruction manipulation, and other adversarial techniques.	0-1	No AI-specific testing.
		2	AI systems in scope for standard pentests, but not deeply tested.
		3	Basic adversarial emulation; defenses mapped to MITRE ATLAS™ techniques.
		4	Dedicated AI red team program; automated adversarial testing in CI/CD; full kill-chain ATLAS coverage.
		5	Continuous adversarial validation; autonomous detection of novel techniques.
5	**Secure AI Development & MLSecOps** Is AI security embedded in the model and agent development lifecycle: threat modeling, secure training pipelines, training data validation, runtime guardrails, and prompt injection detection?	0-1	AI built without security involvement.
		2	Security consulted ad hoc on AI projects.
		3	Architecture standards exist; security integrated into the AI/ML lifecycle.
		4	MLSecOps operational: secure pipelines, model versioning/provenance, real-time prompt injection detection, execution guardrails for agent API calls.
		5	Adaptive, self-improving defenses; chaos engineering validates AI resilience continuously.

Total _____ **Divide by 5** _____ **Protect Score** _____

UTILIZE | USING AI FOR SECURITY

1	**AI-Powered Threat Detection** To what extent do your detection capabilities use AI/ML, and are those models tuned to your environment rather than running at vendor defaults?	0-1	No AI used in detection.
		2	Vendor AI features enabled at defaults; not tuned or validated.
		3	AI-powered detection tuned to your environment; UEBA customized for anomaly detection.
		4	Custom models developed for organization-specific threats; detection accuracy measured.
		5	Predictive defense; cross-organization threat correlation; novel-technique detection.
2	**AI-Assisted Triage, Response & Automation** Are AI capabilities used to triage alerts, accelerate investigation, and automate response through SOAR playbooks?	0-1	Manual processes dominate; no AI assistance.
		2	Some vendor automation; not intentionally configured.
		3	AI-assisted triage and automated playbooks for common scenarios.
		4	SOAR enhanced with AI decision support; autonomous response for validated scenarios.
		5	AI agents authorized for Level 1 remediation; self-healing infrastructure operational.
3	**AI-Enhanced Threat Hunting & Intelligence** Do you use AI to proactively hunt threats and enrich threat intelligence beyond alert-driven workflows?	0-1	No AI used in hunting or intelligence.
		2	Basic vendor enrichment; no proactive use.
		3	AI-powered intelligence enrichment in production; hunting hypotheses informed by AI.
		4	AI-powered hunting and predictive analytics operational; outcomes measured.
		5	Generative AI used for threat simulation and attack prediction.
4	**Security Team AI/ML Capability** Does your security team have the skills to evaluate, deploy, tune, and validate AI security capabilities, supported by defined roles?	0-1	Team unaware of available AI capabilities; no AI/ML skills.
		2	Team beginning to learn about AI threats; no dedicated expertise.
		3	Team competent with AI security tools; AI Security Specialist / AI Governance Lead roles being defined or filled.
		4	Specialist roles operational; structured ongoing training.
		5	Team includes AI researchers; expertise attracts talent and is an organizational differentiator.
5	**Vendor AI Capability Validation** When a vendor markets an "AI" feature, can you distinguish genuine ML capability from AI-washing and validate fit before procurement?	0-1	Vendor claims accepted at face value.
		2	Some skepticism, but no formal evaluation criteria.
		3	Model cards, adversarial testing results, and AI assessment criteria required during procurement.
		4	Validation outcomes tracked; vendors held to measured performance standards.
		5	Organization shapes vendor practices and contributes to industry validation standards.

Total _____ **Divide by 5** _____ **Utilize Score** _____

GOVERN | AI POLICY, RISK & OVERSIGHT

1	**AI Acceptable Use Policy & BYOAI Coverage** Is there a current AI acceptable use policy that addresses both conversational AI and agentic AI, and are employees clear on what's sanctioned?	0-1	No policy; BYOAI proliferates unchecked.
		2	Policy is binary ("don't use AI" or "use with caution"); workarounds common.
		3	Comprehensive policy addressing use cases and data classification; differentiates conversational from agentic AI; sanctioned tools provided.
		4	Policy compliance measured; Shadow AI detection operational; policy refined based on data.
		5	Policy adapts proactively to AI evolution and regulatory change.
2	**AI Governance Structure & Accountability** Is there a named owner or cross-functional committee with a clear charter, decision authority, and review cadence for AI decisions?	0-1	No accountable owner; AI decisions made ad hoc.
		2	Owner exists but lacks formal authority or charter.
		3	AI Governance Committee with charter, decision authority, and regular review cadence.
		4	Governance integrated with risk management; board-level AI risk reporting established.
		5	Governance recognized externally; organization influences industry standards.
3	**AI Risk Management & Quantification** Are AI risks tracked formally on a risk register with a defined assessment methodology, and can you quantify exposure?	0-1	No AI risk assessment conducted.
		2	AI risks acknowledged informally; no formal register entry.
		3	AI risks on the enterprise risk register with defined assessment methodology.
		4	Quantitative methodology adopted; risk appetite formally defined.
		5	Predictive AI risk analytics; governance anticipates emerging risk.
4	**AI Incident Response & Auditability** When an AI system or agent causes harm, can you produce an audit trail proving the chain of authority from human authorization to agent action?	0-1	No AI-specific incident response; ownership unclear.
		2	General incident process applied to AI; no AI-specific procedures.
		3	AI-specific IR procedures; structured logging with trace IDs across agent steps and tool calls; Security vs Reliability ownership defined.
		4	Reasoning traceability and decision audit artifacts produced; AI incident MTTD/MTTR tracked.
		5	Continuous post-incident learning feeds adaptive defenses.
5	**Workforce AI Literacy & Role-Based Training** Has the workforce received AI risk training calibrated to their role, and can the general workforce identify common AI failure modes and escalate anomalies?	0-1	No AI training; workforce unaware of risks.
		2	Basic awareness training mentions AI risks.
		3	Role-based training (general workforce, technical staff, AI-specific roles); employees select tools based on data sensitivity.
		4	Training completion and effectiveness measured; workforce reliably escalates AI anomalies.
		5	AI security expertise attracts external talent; organization mentors others.

Total _____ **Divide by 5** _____ **Govern Score** _____

CALCULATING YOUR AI SECURITY MATURITY SCORE

You should have three pillar scores in front of you, each between 0 and 5. Work through the steps below in order.

STEP 1 | SELECT YOUR INDUSTRY PROFILE

Choose the row that best describes your organization. Protect and Govern are weighted higher than Utilize in the default profile because foundational failures in either Protect or Govern create cascading risk that advanced Utilize capabilities cannot offset. Organizations should select the industry profile that best reflects their risk landscape.

Profile	Protect	Utilize	Govern
Default	35%	30%	35%
Financial Services	40%	25%	35%
Healthcare	35%	25%	40%
Technology / AI-Native	40%	30%	30%
Government / Defense	30%	30%	40%
Critical Infrastructure	30%	35%	35%
Education & Research	30%	25%	45%

STEP 2 | CALCULATE YOUR WEIGHTED PILLAR SCORES

Multiply each pillar score by the weight you selected above.

Protect score ☐ × Protect weight ☐ = **P** ☐

Utilize score ☐ × Utilize weight ☐ = **U** ☐

Govern score ☐ × Govern weight ☐ = **G** ☐

STEP 3 | CALCULATE YOUR RAW OVERALL SCORE

Add lines P, U, and G.

P ☐ + **U** ☐ + **G** ☐ = **Raw Overall Score** ☐

STEP 4 | APPLY THE FOLLOWING CAP RULES

To prevent overstating maturity, two checks apply when calculating your overall stage:

Check 1: Governance Floor Rule

Your overall maturity cannot be more than one stage higher than your Govern pillar score.

For example, if Govern is at Stage 2, your overall maturity cannot exceed Stage 3, even if Protect and Utilize score higher.

This reflects a core principle: without governance as a foundation, higher maturity in other areas creates unmanaged risk.

Govern stage ☐

Maximum permitted overall stage =

Govern stage ☐ + 1 = **Check 1 result** ☐

Check 2: Minimum Pillar Rule

Your overall maturity cannot be more than one stage higher than your lowest-scoring pillar.

For example, if one pillar is at Stage 1, your overall maturity cannot exceed Stage 2, regardless of how strong the other pillars are.

This ensures that major gaps are not masked by strengths elsewhere. Significant imbalances represent structural vulnerability.

Lowest pillar stage ☐

Maximum permitted overall stage =

Lowest pillar stage ☐ + 1 = **Check 2 result** ☐

Take the lower of **Check 1** and **Check 2**. This is your maximum permitted overall stage.

Lower of **Check 1** / **Check 2** = **Maximum permitted overall stage** ☐

STEP 5 | MAP YOUR RAW SCORE TO A STAGE

Find your **Raw Overall Score** from Step 3 in the table.

Raw Score	Stage
0.0 – 0.9	Stage 1: Unaware
1.0 – 1.4	Stage 2: Reactive (Emerging)
1.5 – 1.9	Stage 2: Reactive (Established)
2.0 – 2.4	Stage 3: Defined (Emerging)
2.5 – 2.9	Stage 3: Defined (Established)
3.0 – 3.4	Stage 4: Managed (Emerging)
3.5 – 3.9	Stage 4: Managed (Established)
4.0 – 4.4	Stage 5: Optimizing (Emerging)
4.5 – 5.0	Stage 5: Optimizing (Established)

Stage indicated by raw score ☐

STEP 6 | DETERMINE YOUR FINAL STAGE

The stage at which your organization exists on the Maturity Model is whichever is lower: the stage indicated by your raw score in Step 5, or the maximum permitted overall stage from Step 4.

Your final SANS AI Security Maturity Model Stage ☐

QUICK REFERENCE: AI Security Maturity Model™ CHEAT SHEET

Stage Summary by Pillar

Stage	Protect	Utilize	Govern
1: Unaware	No AI inventory, no threat awareness	No AI used in security tools	No policy, BYOAI unmanaged
2: Reactive	Basic inventory, supply chain awareness	Vendor defaults, no tuning	Policy exists (blocklist/ allowlist), basic training
3: Defined	Adversarial testing, NHI management, ATLAS-informed defense	Tuned detection, enrichment, automation	Governance council, risk register, incident classification
4: Managed	Red teaming, MLSecOps, full ATLAS coverage, Confused Deputy defense	Custom models, threat hunting, SOAR	Quantified risk, regulatory compliance, ethics review
5: Optimizing	Self-improving defenses, Zero Trust agents, chaos engineering	Autonomous operations, predictive defense	Strategic advantage, industry leadership

Framework Alignment

Stage	NIST AI RMF	EU AI Act	ISO 42001	OWASP AI Exchange	CSA AICM
1	Not addressed	Non-compliant	Gap	Not aligned	Not aligned
2	Partial	Basic awareness	Emerging	Awareness	Awareness
3	Risk-informed	Compliance-capable	Implementable	Controls implemented	Implementable
4	Repeatable	Compliant	Certifiable	Comprehensive	Comprehensive
5	Adaptive	Leadership	Advanced	Contributing	Contributing

MATURE YOUR PROGRAM WITH SANS

Advancing through the AI Security Maturity Model™ requires training that is practical, hands-on, and built for the practitioners doing this work. SANS offers a comprehensive portfolio of AI security courses aligned to the three pillars, designed to help organizations address the capability gaps identified through the maturity assessment.

PROTECT AI

- **SEC545: Securing AI-Powered Applications and LLM Workflows**
- **SEC411: Generative AI and LLM Security**
- **SEC495: Build and Secure RAG / Agentic Stacks**

UTILIZE AI

- **SEC598: AI and Security Automation for Red, Blue, and Purple Teams**
- **SEC595: Applied Deep Learning for Security**
- **SEC535: AI for Offensive Operations**

GOVERN AI

- **LDR514: Security Strategic Planning, Policy, and Leadership**
- **LDR519: Cybersecurity Governance, Risk, and Compliance**
- **LDR520: Cloud Security Leadership for AI Workloads**

The Assessment can be used to develop a prioritized training plan by highlighting the capability gaps that most impact maturity. The courses shown above are representative of how those gaps can be addressed.

Put This Model Into Practice

Explore additional resources and training at **SANS.org/ai**
Or **connect with SANS** to discuss how this framework applies to your organization.

ATTRIBUTION AND SOURCES

This model incorporates concepts from and aligns with:

1. **SANS Secure AI Blueprint**
   Foundation framework (Protect, Utilize, Govern)
2. **SANS Critical AI Security Guidelines v1.3**
   Technical control alignment
3. **OWASP AI Exchange Essentials**
   Co-developed AI security standards
4. **NIST AI Risk Management Framework (AI RMF)**
   AI risk management methodology
5. **MITRE ATLAS™**
   AI threat landscape and attack techniques
6. **EU AI Act**
   AI regulatory compliance concepts
7. **ISO/IEC 42001**
   AI management system concepts
8. **CISA's Principles for the Secure Integration of Artificial Intelligence in Operational Technology**
   Government AI security guidance
9. **SANS 2025 AI Survey**
   Empirical data on AI adoption and security practices
10. **SANS AI Career Framework and Workforce Report**
    Role definitions and workforce data
11. **CSA AI Controls Matrix (AICM)**
    AI security controls for cloud-based systems
12. **CSA AI Safety Initiative**
    Industry consensus-driven effort developing AI guidance, best practices, and tools

The AI Security Maturity Model™ provides what these standards do not: operational specificity for security teams, a three-pillar maturity structure, practitioner-level action plans at every stage, an evidence-based scoring methodology calibrated for inter-rater reliability, and direct connection to training pathways that close identified gaps.

The author thanks the SANS AI security research community, OWASP AI Exchange contributors, and the practitioners who validated this framework through field assessments for their contributions to its development.

Special thanks to reviewers:

Behnaz Karimi
Senior Cybersecurity Engineer and Independent Ransomware Researcher; Co-lead, OWASP AI Exchange

Rock Lambros
Director of AI Standards and Governance, Zenity

Rob van der Veer
Chief AI Officer, Software Improvement Group; Founder, OWASP AI Exchange

Matt Bromiley
Security Research and Development, Prophet Security

Chris Hughes
VP Security Strategy, Zenity

Nikki Robinson, DSc, PhD

Nicole Darden Ford
Vice President, Customer Security Officer, Microsoft

Ron Eddings
GenAI Researcher and CEO, Mozilla and Hacker Valley Media

Chen Pipek
Co-founder and CPO, Aizome

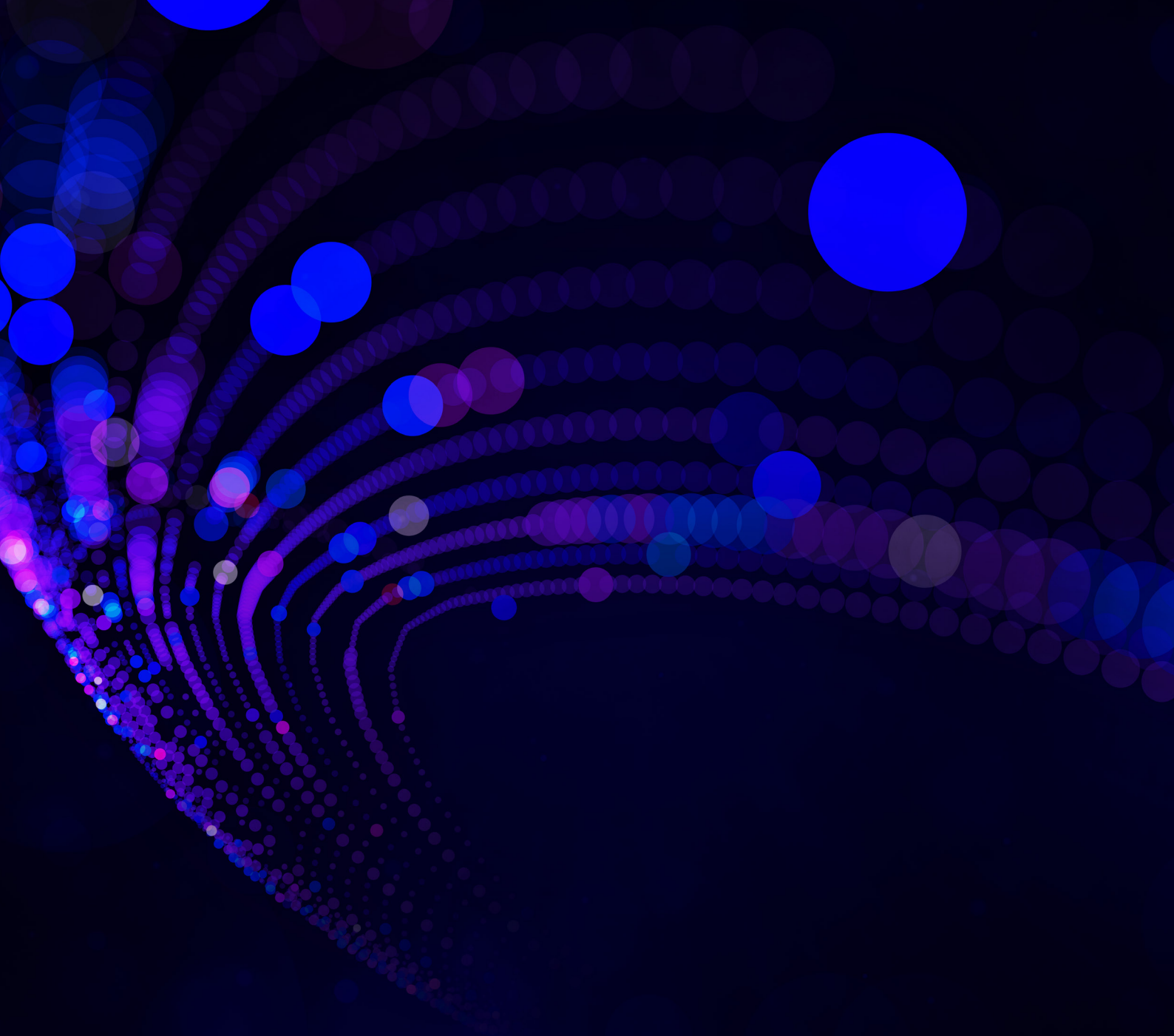
Amir Ofek
Co-founder and CEO, Aizome

John Yeoh
Chief Scientific Officer and EVP of R&D, Cloud Security Alliance



ABOUT THE AUTHOR

Chris Cochran is the Field CISO and Vice President of AI Security at the SANS Institute, a Marine Corps veteran, and a former security leader at Netflix, NSA, Mandiant, the U.S. House of Representatives, and Axonius. He is a co-author of prEN 18282, the Harmonized Standard for AI Cybersecurity under the EU AI Act, a contributing author to the OWASP AI Vulnerability Scoring System (AIVSS) Project, and serves as the Agentic AI Task Force Lead for the OWASP AI Exchange. His work spans AI governance, model risk, multi-agent system security, and adversarial AI, blending deep operational cyber experience with cutting-edge research to help organizations navigate emerging AI threat landscape. Known for translating fast-moving technical complexity into actionable insight, Chris is focused on building a future where AI systems are both powerful and safe.



SANS

Explore additional resources and training at **SANS.org/ai**

© 2026 SANS Institute. All Rights Reserved.